

CÓMO PROTEGER ENTORNOS OT, ICS Y SCADA

Guía práctica de ciberseguridad industrial, seguridad física, resiliencia, arquitectura, monitoreo, incidentes y gobierno

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

CC BY-NC-SA 4.0

Propósito y aviso de uso responsable

Este manual ofrece orientación defensiva para organizaciones que poseen u operan tecnología operacional. Los cambios en OT pueden afectar procesos físicos, seguridad de trabajadores y comunidades, calidad del producto y condiciones ambientales. Toda prueba, análisis, cambio de configuración y acción de respuesta debe estar autorizada y coordinada con operaciones, ingeniería, seguridad física y propietarios de los equipos.

La seguridad física antes que la ciberseguridad. Si una acción cibernética puede desestabilizar un proceso, deténgase y obtenga aprobación operacional.

Tabla de contenido

- 1. Comprender OT, ICS y SCADA
- 2. Por qué OT es diferente de TI
- 3. Gobierno y responsabilidad compartida
- 4. Inventario y contexto del sistema
- 5. Evaluación de riesgos e integración con seguridad física
- 6. Arquitectura segura, zonas y conductos
- 7. Identidad y control de acceso
- 8. Acceso remoto y soporte de terceros
- 9. Seguridad de red y protocolos industriales
- 10. Configuración segura y control de cambios
- 11. Vulnerabilidades y parches
- 12. Protección de endpoints, servidores y estaciones de ingeniería
- 13. Copias, recuperación y resiliencia
- 14. Monitoreo y detección
- 15. Defensa informada por amenazas con MITRE ATT&CK para ICS
- 16. Respuesta a incidentes OT
- 17. Preparación frente a ransomware y eventos destructivos
- 18. Cadena de suministro y proveedores
- 19. Nube, IIoT, edge y redes inalámbricas
- 20. Seguridad física y controles ambientales
- 21. Cumplimiento, evidencia y métricas
- 22. Hoja de ruta de 30, 60 y 90 días
- 23. Listas y artefactos de ejemplo
- 24. Glosario y referencias oficiales

1. Comprender OT, ICS y SCADA

- La tecnología operacional incluye sistemas y dispositivos que supervisan o controlan procesos físicos.
- Los sistemas de control industrial pueden incluir DCS, PLC, sistemas instrumentados de seguridad, RTU, HMI, historiadores, estaciones de ingeniería y dispositivos de campo.
- SCADA suele apoyar supervisión y control geográficamente distribuidos, como electricidad, agua, oleoductos, transporte y medio ambiente.
- Documente la consecuencia física de cada función digital crítica.

2. Por qué OT es diferente de TI

- La seguridad física, la estabilidad, la confiabilidad y la disponibilidad suelen tener prioridad sobre cambios rápidos.
- Los dispositivos heredados pueden tener ciclos de vida largos, recursos limitados, protocolos propietarios y sistemas sin soporte.
- El escaneo activo, las pruebas agresivas, la corrección automática o los reinicios no planificados pueden interrumpir producción o crear condiciones inseguras.
- La recuperación puede requerir validación de ingeniería, inspección física, calibración y secuencias controladas.
- Las decisiones deben incluir operaciones e ingeniería, no solamente TI.

3. Gobierno y responsabilidad compartida

- Defina propiedad ejecutiva del riesgo cibernético OT.
- Cree un comité con operaciones, ingeniería, seguridad física, TI, ciberseguridad, asuntos legales, compras y continuidad.
- Asigne propietarios de sistemas, activos, redes, seguridad y decisiones de incidentes.
- Establezca estándares para arquitectura, acceso, soporte remoto, registros, copias, cambios e incidentes.
- Documente autoridad de aceptación de riesgo y vencimiento de excepciones.

4. Inventario y contexto del sistema

- Inventarie hardware, software, firmware, sistemas operativos, controladores, redes, sistemas virtuales, radios, sensores, actuadores y sistemas de seguridad.
- Registre fabricante, modelo, serie, firmware, ubicación, función, propietario, dirección, dependencias, criticidad, soporte y método de copia.
- Use descubrimiento pasivo cuando sea posible y valide con documentación e inspección física.
- Mantenga diagramas, flujos, dependencias y una línea base aprobada.
- Identifique activos desconocidos, no administrados, sin soporte y temporales.

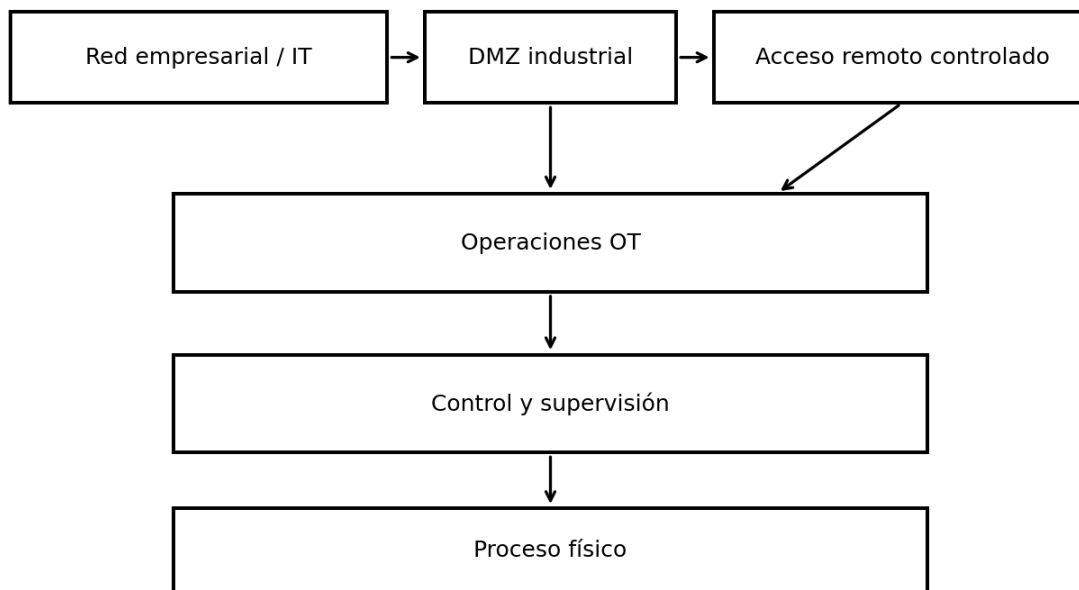
5. Evaluación de riesgos e integración con seguridad física

- Defina consecuencias operacionales, de seguridad, ambientales, calidad, financieras y de servicio público.
- Modele pérdida de visibilidad, pérdida de control, manipulación, denegación, estado inseguro y pérdida de protección.
- Evalúe amenazas, vulnerabilidades, salvaguardas, probabilidad, consecuencia y capacidad de recuperación.
- Integre el riesgo cibernético con análisis de peligros, seguridad de procesos, impacto empresarial y riesgo corporativo.
- Prefiera tratamientos que reduzcan exposición sin debilitar seguridad o confiabilidad.

6. Arquitectura segura, zonas y conductos

- Agrupe activos en zonas según función, criticidad, confianza y nivel de seguridad.
- Use conductos con reglas explícitas entre zonas.
- Separe TI empresarial, DMZ industrial, operaciones OT, control, seguridad y campo.
- Minimice conexiones directas e impida acceso no controlado a Internet.
- Use firewalls, diodos de datos, gateways, jump hosts y proxies cuando corresponda.
- Documente cada flujo, propietario, protocolo, dirección, propósito y monitoreo.

Arquitectura OT segmentada con zonas y conductos



Toda conexión debe tener propietario, propósito, autenticación, monitoreo y reglas documentadas.

7. Identidad y control de acceso

- Use cuentas nominales y elimine administradores compartidos cuando sea técnicamente posible.
- Separe operadores, ingenieros, mantenimiento, proveedores y seguridad.

- Use MFA en acceso remoto, jump hosts, VPN y administración privilegiada.
- Aplique privilegio mínimo y acceso temporal.
- Proteja cuentas de servicio e identidades de máquina; rote credenciales mediante cambios aprobados.
- Revise acceso después de cambios laborales, fin de contratos, incidentes y retiro.

8. Acceso remoto y soporte de terceros

- Prohíba acceso remoto directo no administrado a controladores y estaciones de ingeniería.
- Exija VPN o acceso de confianza cero aprobado, MFA, jump host, registro de sesión y autorización temporal.
- Habilite acceso durante ventanas aprobadas cuando sea posible.
- Exija identidad, propósito, sistemas, comandos esperados y duración.
- Monitoree sesiones y termine acceso inactivo.
- Mantenga un método de emergencia para deshabilitar acceso remoto sin afectar operaciones seguras.

9. Seguridad de red y protocolos industriales

- Use reglas de denegación predeterminada entre zonas.
- Permita únicamente origen, destino, protocolo, puerto y dirección necesarios.
- Muchos protocolos industriales no fueron diseñados con autenticación o cifrado fuertes.
- Use monitoreo consciente del protocolo y firewalls industriales cuando corresponda.
- Proteja sincronización de tiempo, resolución de nombres, enrutamiento y administración.
- Deshabilite puertos, servicios, interfaces inalámbricas y accesos ocultos sin uso.
- Pruebe cambios en un entorno representativo.

10. Configuración segura y control de cambios

- Cree líneas base para controladores, HMI, servidores, estaciones, redes y sistemas de seguridad.
- Deshabilite servicios innecesarios y cuentas predeterminadas.
- Use listas permitidas de aplicaciones cuando sean compatibles y seguras.
- Exija revisión, aprobación operacional, copias, reversión y validación.
- Registre cambios de lógica, firmware, puntos de ajuste, cuentas y reglas de red.
- Use verificación de integridad o control de versiones para configuraciones y lógica críticas.

11. Vulnerabilidades y parches

- Monitoree avisos de fabricantes, alertas CISA, soporte, vulnerabilidades explotadas y controles compensatorios.
- No aplique parches solo por una puntuación alta; considere exposición, explotación, seguridad, proceso y recuperación.
- Pruebe parches y firmware en un entorno representativo.
- Programe mantenimiento con operaciones y prepare copias y reversión.

- Use segmentación, listas permitidas, parches virtuales, monitoreo y restricciones cuando no sea seguro parchear.
- Documente aceptación de riesgo y revísela.

12. Protección de endpoints, servidores y estaciones de ingeniería

- Use estaciones de ingeniería dedicadas.
- Restrinja correo, navegación, software personal y tareas de oficina en endpoints OT.
- Controle medios removibles y use estaciones de análisis.
- Proteja administrador local y deshabilite cuentas innecesarias.
- Implemente protección de endpoint solamente después de validar compatibilidad y desempeño.
- Mantenga instaladores, licencias, controladores, configuraciones y medios de recuperación sin conexión.

13. Copias, recuperación y resiliencia

- Respalde lógica de controladores, proyectos HMI, historiadores, imágenes, redes, certificados, licencias, recetas y datos críticos.
- Mantenga copias protegidas sin conexión o inmutables.
- Pruebe restauración con ingeniería y operaciones.
- Documente dependencias y secuencias seguras de reinicio.
- Mantenga repuestos, firmware aprobado, medios y contactos.
- Ejercite operación manual o degradada cuando sea posible.

14. Monitoreo y detección

- Recopile eventos de red, firewall, acceso remoto, identidad, endpoints, servidores, historiadores y controladores según capacidad.
- Use monitoreo pasivo y análisis de protocolos industriales.
- Establezca línea base de comunicaciones, ingeniería, descargas de lógica, firmware, nuevos dispositivos y sesiones.
- Alerte sobre activos nuevos, protocolos inesperados, cambios de lógica, protecciones deshabilitadas, comandos inusuales y tráfico entre zonas.
- Las detecciones deben revisarse con conocimiento de ciberseguridad y del proceso físico.

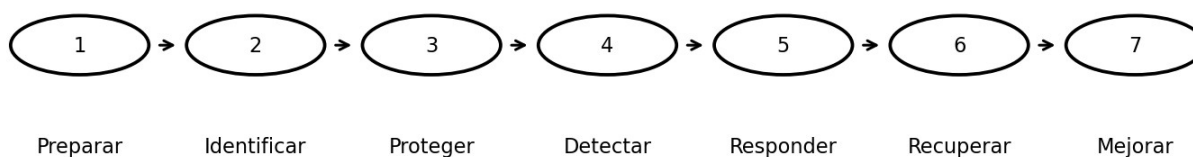
15. Defensa informada por amenazas con MITRE ATT&CK para ICS

- Use ATT&CK para ICS para comprender objetivos y técnicas observadas.
- Mapee técnicas a telemetría, controles, detecciones, respuesta y recuperación.
- Priorice escenarios relevantes para el sector, arquitectura y exposición.
- No trate ATT&CK como una lista de cumplimiento.
- Use ejercicios de mesa y validación segura, no técnicas peligrosas en producción.

16. Respuesta a incidentes OT

- Cree un plan específico integrado con seguridad, operaciones, ingeniería, seguridad física, asuntos legales, comunicaciones y respuesta empresarial.
- Defina quién puede aislar redes, detener procesos, deshabilitar acceso, cambiar lógica o iniciar apagado.
- Conserve registros, configuraciones, estado de controladores, capturas y evidencia física.
- Contenga con cuidado; desconectar puede eliminar visibilidad o crear un estado inseguro.
- Use recuperación controlada y verifique integridad del proceso.
- Realice lecciones aprendidas y actualice diagramas, controles, guías y capacitación.

Ciclo de seguridad y resiliencia OT



La seguridad debe preservar la seguridad física, la confiabilidad y la continuidad del proceso.

17. Preparación frente a ransomware y eventos destructivos

- Segmente OT de TI y restrinja relaciones administrativas.
- Proteja copias y cuentas de recuperación de la misma ruta de ataque.
- Prepárese para pérdida de identidad, virtualización, archivos, acceso remoto, historiadores y estaciones.
- Identifique operaciones mínimas viables y alternativas manuales.
- Ejercite comunicaciones sin correo corporativo.
- No reconecte sistemas restaurados sin verificarlos.

18. Cadena de suministro y proveedores

- Evalúe fabricantes, integradores, mantenimiento, software, servicios administrados, nube y soporte remoto.
- Exija desarrollo seguro, divulgación, integridad de actualizaciones, soporte, notificación y acceso controlado.
- Verifique fuentes de firmware, software y configuraciones.
- Controle productos sin soporte y planes de reemplazo.
- Evalúe subcontratistas y cuartas partes.

19. Nube, IIoT, edge y redes inalámbricas

- Inventarie sensores conectados, gateways, analítica, gemelos digitales, telemetría, módems y redes inalámbricas.
- Separe administración de nube del control directo cuando sea posible.
- Use identidad fuerte, certificados, cifrado y salidas controladas.
- Valide comportamiento seguro cuando fallen nube o comunicaciones.
- Proteja actualizaciones y plataformas edge.
- Evalúe residencia de datos, privacidad, acceso del proveedor y dependencia externa.

20. Seguridad física y controles ambientales

- Controle acceso a salas, gabinetes, armarios de red, sitios de campo y equipos portátiles.
- Monitoree manipulación, conexiones no autorizadas, gabinetes abiertos y reemplazo de dispositivos.
- Proteja energía, refrigeración, incendios, agua, ambiente y generación de respaldo.
- Coordine investigaciones físicas y cibernéticas.
- Trate sitios remotos sin personal como ambientes de mayor exposición.

21. Cumplimiento, evidencia y métricas

- Mantenga evidencia de inventarios, diagramas, riesgos, aprobaciones, acceso, copias, restauración, cambios, vulnerabilidades, capacitación, ejercicios, incidentes y correcciones.
- Mapee controles a NIST CSF 2.0, NIST SP 800-82 Rev. 3, ISA/IEC 62443, requisitos sectoriales y políticas.
- Mida reducción de riesgo, no solamente actividades.
- Métricas útiles incluyen activos no administrados, activos sin soporte, excepciones remotas, hallazgos vencidos, restauración, cobertura de detección y ejercicios.
- Identifique claramente NIST SP 800-82 Rev. 4 como trabajo previo al borrador y no como guía final vigente.

22. Hoja de ruta de 30, 60 y 90 días

- Días 1 a 30: establecer propietarios, identificar procesos críticos, inventariar activos prioritarios, documentar acceso remoto, validar copias y revisar rutas TI-OT.
- Días 31 a 60: crear zonas y conductos, reducir accesos, establecer línea base, definir vulnerabilidades y escribir guías de incidentes.
- Días 61 a 90: probar restauración, ejercitar ransomware y pérdida de visibilidad, validar detecciones, formalizar proveedores y crear métricas ejecutivas.

23. Listas y artefactos de ejemplo

Lista de preparación para producción

- ☐ Procesos críticos y consecuencias de seguridad documentados

- ☐ Inventario y diagramas validados
- ☐ Propietarios y autoridad de incidentes asignados
- ☐ Zonas y conductos aprobados
- ☐ Acceso remoto controlado y monitoreado
- ☐ Cuentas nominales, MFA y acceso privilegiado revisados
- ☐ Copias protegidas y restauración probada
- ☐ Proceso de vulnerabilidades operativo
- ☐ Líneas base y control de cambios establecidos
- ☐ Monitoreo pasivo y detecciones prioritarias habilitados
- ☐ Plan de incidentes y decisiones de contención documentados
- ☐ Ejercicio de ransomware y pérdida de visibilidad completado
- ☐ Riesgos de proveedores y productos sin soporte controlados
- ☐ Procedimientos manuales o degradados revisados
- ☐ Aceptación ejecutiva de riesgo registrada

Campos de inventario OT

Campo	Ejemplo
ID del activo	OT-PLC-001
Función	Control de agua de alimentación de caldera
Propietario	Operaciones de planta
Fabricante / modelo	Modelo de controlador aprobado
Firmware / SO	Versión validada
Ubicación	Planta 2 - Gabinete B
Zona	Control básico del proceso
Criticidad	Crítica
Impacto de seguridad	Posible parada y daño a equipos
Dependencias	HMI, historiador y estación de ingeniería
Acceso remoto	Proveedor solo mediante jump host aprobado
Copia	Lógica verificada trimestralmente
Soporte	Soportado hasta 2028
Última revisión	2026-07-18

Ejemplo de riesgo OT

Riesgo: Una cuenta compartida de proveedor con acceso remoto permanente podría ser comprometida y usada para modificar lógica de controladores. Impacto: Pérdida de control, condiciones inseguras,

interrupción y daño a equipos. Tratamiento: Sustituir la cuenta por identidades nominales, MFA, aprobación temporal, sesiones monitoreadas, alertas de cambios y revisión trimestral.

24. Glosario y referencias oficiales

Término	Definición
OT	Tecnología que supervisa o controla procesos, dispositivos e infraestructura física.
ICS	Sistemas de control industrial.
SCADA	Supervisión, control y adquisición de datos distribuidos.
PLC	Controlador lógico programable.
HMI	Interfaz hombre-máquina usada por operadores.
SIS	Sistema instrumentado de seguridad para llevar un proceso a un estado seguro.
Zona	Grupo de activos con requisitos comunes de seguridad.
Conducto	Ruta controlada de comunicación entre zonas.
Historiador	Sistema que almacena datos de proceso en series de tiempo.
Estación de ingeniería	Sistema usado para configurar y programar activos industriales.

Referencias oficiales

- NIST SP 800-82 Rev. 3 - Guide to Operational Technology Security: <https://csrc.nist.gov/pubs/sp/800/82/r3/final>
- NIST SP 800-82 Rev. 4 - Pre-Draft Call for Comments: <https://csrc.nist.gov/pubs/sp/800/82/r4/iprd>
- NIST Cybersecurity Framework 2.0: <https://www.nist.gov/cyberframework>
- ISA/IEC 62443 Series of Standards: <https://www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards>
- MITRE ATT&CK for ICS: <https://attack.mitre.org/matrices/ics/>
- CISA Cross-Sector Cybersecurity Performance Goals: <https://www.cisa.gov/cross-sector-cybersecurity-performance-goals>
- CISA Industrial Control Systems Resources: <https://www.cisa.gov/topics/industrial-control-systems>

Licencia

Copyright © 2026 Alberto (Al) Leiva. Distribuido bajo la licencia CC BY-NC-SA 4.0.